

A systematic approach to analysis for assessing the security level of cyber-physical systems in the electricity sector

Miguel Ángel Sánchez Rodríguez, Javier Bermejo Higuera, Juan Ramón Bermejo Higuera, Juan Antonio Sicilia Montalvo*, Rubén González Crespo

Escuela Superior de Ingeniería y Tecnología, Universidad Internacional de La Rioja, Avenida de La Paz, 137, La Rioja 26006, Spain

ARTICLE INFO

Keywords:

Energy sector
IEEE 1686
ISO 62351
Smartgrid cybersecurity
SCADA cybersecurity
Security analysis
Security audit

ABSTRACT

In a context of digitalization and technological evolution in all aspects of our lives, the electricity sector could not be left behind. This opens up a new range of possibilities until now unthinkable, which will facilitate the progress and services that we will be able to enjoy thanks to the development of the smart grid. But it also poses new challenges, both technological and in terms of cybersecurity, as the electricity sector takes on an increasingly important role in our lives. Therefore, after an analysis of the main incidents that have affected the energy sector, a general study is made of the standards that affect it, especially the IEEE 1686 and IEC 62,351 standards, in order to develop a simple and practical methodology to assess the level of security of the cyber-physical systems and equipment that makes up an electrical installation. The aforementioned methodology is developed based on a selection of specific requirements from the aforementioned standards that will serve as a starting point for the development of a series of specific compliance tests to assess the equipment to be installed or modified in a smart grid. This is because every measure is too little to put a stop to the successes achieved so far by cybercriminals. To this end, it is necessary to set out one of the many routes initiated by the many standards, norms, and laws, and thus define an effective and efficient path that will allow us to establish secure pillars on which to build the future.

1. Introduction

This article analyses the status of the application of security measures in the electricity sector, which has traditionally been dominated by electrical engineering and industrial electronics, and in which Information and Communications Technologies (ICT) have gradually been making inroads at different levels of the substation to improve them and increase their possibilities and efficiency, but which are in turn gradually becoming more exposed to cyber-attacks. This has produced an important development of the smart grid, which according to Delgado-Gomes [1] can be defined as “a power network operated using an ICT communication layer, managing two bidirectional flows: electrical and informational”.

One of the results of this evolution is the emergence of new weaknesses and vulnerabilities that were hitherto hidden, as demonstrated by security incidents that have had very serious impacts. An example of this is the attacks on Ukraine [2], the main root cause of which was a lack of

cybersecurity awareness, which also entails other types of problems: lack of corporate policies, lack of security awareness, lack of specific information security requirements. Even with the existence of regulations, recommendations, and good practice guides for many years now, this lack of awareness has meant that these measures have not been implemented as they are not mandatory.

Threats such as Stuxnet, Industroyer or Triton, which are detailed in the following section, show that critical infrastructures are vulnerable and must be duly protected, working not only on their resistance to attacks, but also on their resilience (recovery as quickly as possible) and traceability (identifying the origin, affected systems, etc.). Awareness and maturity need to be raised, as evidenced by actions such as the mock cyber-attack conducted in the US [3] in November 2018. Through close collaboration between government and industry researchers, a cyber-attack on the electricity grid was simulated to test incident response plans, including supply chain vulnerabilities, recovery and business continuity programs and misconfigured equipment, with the

* Corresponding author.

E-mail addresses: miguel.sanchez@arteche.com (M.Á. Sánchez Rodríguez), javier.bermejo@unir.net (J. Bermejo Higuera), juanramon.bermejo@unir.net (J.R. Bermejo Higuera), juanantonio.sicilia@unir.net (J.A. Sicilia Montalvo), ruben.gonzalez@unir.net (R. González Crespo).

<https://doi.org/10.1016/j.micpro.2021.104352>

Received 24 March 2021; Received in revised form 6 August 2021; Accepted 19 October 2021

Available online 23 October 2021

0141-9331/© 2021 Elsevier B.V. All rights reserved.

intention of measuring resilience by restoring service from zero (black start), and to determine the source of the attack. According to Walter Weiss, head of the Rapid Attack Detection, Isolation and Characterization Systems (RADICS) program [4], the simulation was conducted in the most unfavorable scenario, they discovered all kinds of flaws during the month-long exercise and were able to assess the validity of the tools they used.

Taking into account the aforementioned cybersecurity problems in the electricity sector for the following research the following general hypothesis has been established:

"There are currently many devices in Smart Grid production environments that have not been assessed, and which hide multiple vulnerabilities, due to the fact that in their design and development they did not establish security requirements. These could be minimized by conducting a security audit according to industry standards and requirements and recent technological advances in IT security".

Based on the above hypothesis, the following research questions were established:

- Are there regulations in the electricity sector, and initiatives for their implementation, that incorporate the necessary security requirements to be evaluated and audited?
- Is it possible to develop a basic methodology for auditing and assessing the equipment to be installed in a Smart Grid to verify compliance with the security requirements selected on the basis of the regulations, which can be extended and adapted to objectively increase the level of security of the installations?

In order to answer the established research hypothesis and its associated questions, a study of the state of the art and the cyber security regulations in the electricity sector has been carried out in the present research and has been developed a simple and practical methodology has been developed to establish a baseline on which to start improving the security of the cyber-physical systems (CPS) installed in smart grids. This methodology makes it possible to assess the security level of the CPSs that make up an electrical installation based on the establishment of specific requirements and specific compliance tests.

The document is structured as follows. Section 2 analyses the current knowledge available on cyber-attacks on the electricity sector, similar works and the standards applicable to smart grid security. Subsequently, Section 4 includes the methodology for analyzing the security level of the cyber-physical systems to be implemented in a smart grid and Section 5 includes the results obtained from a case study carried out to test the aforementioned methodology. Finally, Section 6 includes the conclusions and future directions of the research.

2. Background and related work

Electricity is a basic necessity that allows the world to function. As proof of this, we invite the reader to carry out the personal exercise of thinking about what would happen if a problem caused the absence of electricity for one, two hours, or even one day, as happened in 2019 on the island of Menorca (Spain), where, due to physical problems (collapse of several electricity pylons), there were three days without electricity, causing millions of dollars in losses, closed businesses, no water, no electricity, no money (ATMs did not work) [5]. Such is the integration of electricity in the daily life of society that we only think about it when we lack it, or when the news announces a new historical maximum in the price of the kilowatt/hour (kW/h).

Events such as these could lead us to think that we are facing a scenario of black swans (events of very low probability, but with a very high impact), but this is a big mistake. Obviously, there will be black swans, but a cyber-attack should not be treated as such, since the technical means, the difficulty of pinpointing the origin of the attack, conflicts between states, industrial espionage... in recent years have also put critical infrastructures and their value chain in the spotlight, which

includes suppliers that are more difficult to control, and data can be extrapolated to work with an estimation of probabilities.

The big challenge facing the traditional electricity grid, as explained in [6], is that energy cannot be stored. Energy has to be generated according to consumption (demand), and an error in this task can lead to instability and blackouts, so it is a great responsibility of the grid operator to manage all the available information and have resources to maintain grid stability with the fluctuations in consumption that exist. But this is complicated by the arrival of new technologies such as the electric car, which involves high consumption, but also a form of large-scale energy storage, which could be used to stabilize the grid, or with the change in the generation scheme, from having a few very powerful plants to many low-power plants (DER), etc.

With a need to improve infrastructure and management to make it increasingly efficient and prepare the sector for what is to come, the existing electricity grid has to evolve by becoming "smarter", giving rise to what is known as the smart grid. Fig. 1. [7] shows the conceptual model of such an infrastructure.

According to [7] the smart grid consists of the following parts:

- Generation: Produce energy from different sources, giving name to the generating plant: thermoelectric power plants, hydroelectric power plants, renewable energy power plants, etc.
- Transmission: Control the energy generated, raising it to voltages of the order of 220 kV and 400 kV, and transporting it for distribution over large areas. It would be analogous to energy highways.
- Distribution: These are supplied from the transmission grid and distribute the energy to end-users.
- Customer: Comprises domestic users, homes, businesses, and industry (factories, trains, etc.), services (street lighting, hospitals, etc.), which transform the energy into something useful (light, heat, powering machines, devices, charging electric cars, and a long etc.).
- Operations: Supervisory Control and Data Acquisition (SCADA) system connected to the entire grid, from which the state of the electricity system, demand and generation parameters, events and alarms, etc. are monitored and controlled.
- Services Provider: These are the different electricity supply companies that establish contracts with the different types of users.
- Market. These are the different suppliers that generate electricity and offer it for sale on the market.

As indicated in [7], this concept represents a radical change in the philosophy of the traditional electricity grid. It is true that it already has a certain "intelligence", but the key here is that it adds two-way communication between the electricity company and the consumer, opening up a wide range of possibilities, but also posing new challenges in terms of security, as it involves introducing "intelligence" at all levels, going from using a system that controls the others, to an installation full of equipment that communicates with each other, called Intelligent Electronic Device (IED), which constitute CPS-type systems [8]. Here the term "intelligent" is used in the sense that it has its own processing unit, program and configuration, so that it is autonomous in its functions, reports its status to other equipment and receives orders from higher levels such as SCADA.

These devices (CPS) are necessary to make the electricity grid as a whole more efficient, matching generation to demand as automatically and intelligently as possible, which is, as indicated above, one of the key points of grid management. However, their connection to the network gives rise to new dangerous security challenges. According to the reference article [9] the main threats to which these systems are exposed are the following: Wireless exploitation, jamming, reconnaissance, remote access, disclosure of information, unauthorised access, interception, GPS exploitation and information gathering.

Cybersecurity in the smart grid is undergoing an evolution, which has been particularly intense in recent years. The companies that manage these critical infrastructures do so from two very different

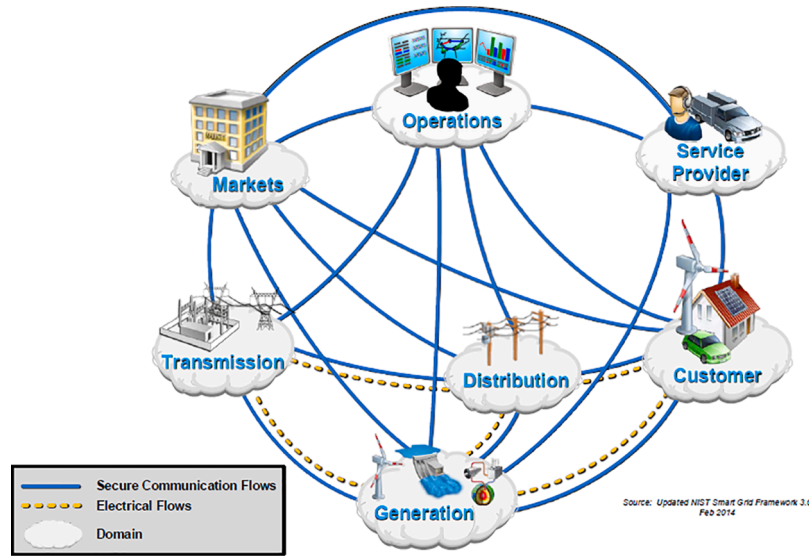


Fig. 1. Conceptual model of a smart grid [7].

approaches. The corporate part, in which information technologies (IT) predominate, and the operational technologies part of the utilities (OT). It is very common for companies responsible for the operation of this type of critical infrastructure to have a mixture of corporate processes and infrastructure operation processes, which is why they require a mixed intranet. A reference approach was defined by ISA95, in the purdue model. In this scenario, these companies have implemented physical and logical perimeter security, protecting accesses, although not enough[10].

Despite documented good practices from several standards and regulatory bodies, such as ENISA, DHS, NERC or NIST (just to name a few), smart grid cyber security reports such as "Outsmarting Grid Security Threats" [11], conducted by Accenture, state that more than 50% of electricity company executives (out of more than 100 interviewed), feel that they may be victims of an attack affecting electricity supply in the next five years. There are several reasons for this concern, including a failure to follow good practice and long technology lifecycles, which often involve keeping outdated systems in production, constituting a dangerous "long tail" with serious risks to confidentiality, integrity, and availability (CIA).

Specifically, in the electricity sector, which has traditionally been dominated by electrical engineering and the electronics industry, information, and communication technologies (ICTs) have gradually broken into the different levels of the infrastructure to improve them and increase the possibilities and efficiency, but they are increasingly

exposed to cyber-attacks. With this evolution, deficiencies and vulnerabilities have emerged that were until recently hidden, as demonstrated by security incidents that have had very serious impacts (such as the attacks on the Ukraine [12], whose main root cause was a lack of awareness, leading to other problems: lack of corporate policies, lack of security awareness, absence of specific information security requirements or simply disregarding of existing good practices and recommendations.

Fig. 2 based on the list of incidents from [13], provides a chronology of the most famous incidents affecting the energy sector.

Some of these incidents, which are next discussed some of them into detail, have been increasing in number and complexity:

- 2015: BlackEnergy, or Ukraine. On 23 December 2015, in the middle of winter, a 6-hour blackout affected around 80,000 customers, according to the power company under attack, Kyivoblenergo (although it was later revealed that 225,000 customers could have been affected). The virus causing the problem, BlackEnergy 3, would be the first to deliberately cause a large-scale power outage [12].
- 2016: Industroyer / CrashOverride, or Ukraine II. One year after the attack with BlackEnergy, another malware is used (allegedly by Team Sandworm) to launch another attack against the power supply in Ukraine. The malware specimen was analyzed by ESET, who called it Industroyer, and a little later by the company Dragos, who

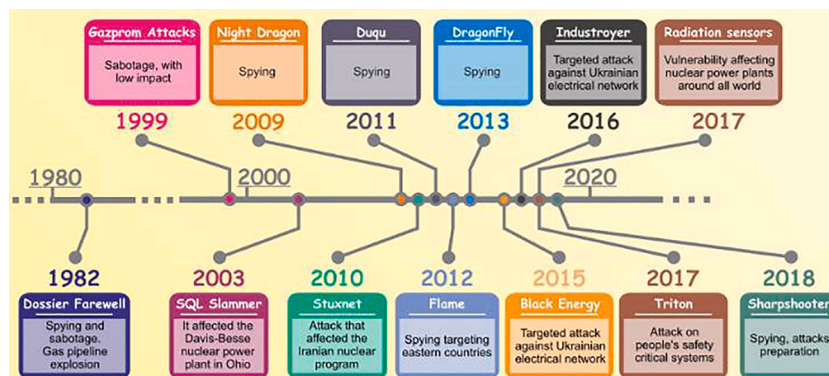


Fig. 2. Timeline with the most important incidents.

called it CrashOverride, so it can be referred to indistinctly by the two names [14].

- 2017: Triton. In this case, the security company FireEye reported in December 2017 on the detection of a new malware affecting industrial equipment used in critical infrastructure to ensure the safety of people, among other functions. Akin to Stuxnet, it was developed to attack Schneider Electric Triconex systems [15]
- 2017: Vulnerability in nuclear power plant sensors worldwide. In this case, as can be read in [16], when Rubén Santamarta, discovered a security problem in the sensors that monitor radioactivity in the vicinity of nuclear power plants, which allowed him to falsify the data sent to the SCADA, allowing him to create a false alarm or mask a real one. This is because these radioactivity sensors send the radiation measurements by radio frequency. In [17] it is also stated that such sensors are also used in other critical infrastructures, such as hospitals.
- 2018: Operation Sharpshooter. In December 2018, the advanced threat research team of the security company McAfee®, together with the operations group of the malware laboratory of the same company, published the report [18] on a campaign of attacks, which they have named Operation Sharpshooter, aimed at nuclear, defense, energy and financial targets, affecting a total of 87 companies.

Apart from the above incidents, malware samples have also been detected without actually acting, such as SFG [19] or Irongate [20] which, although they represented new developments such as the detection of virtualized environments and sandboxes, the feeling is that they were proofs of concept that attackers would have used to learn more about the critical systems they were going to attack.

All these attacks were due to several vulnerabilities [21], such as:

- Customer security: Smart meters autonomously collect massive amounts of data and transport it to the utility company, consumer, and service providers. This data includes private consumer information that might be used to infer consumer's activities, devices being used, and times when the home is vacant.
- Greater number of intelligent devices that may act as attack entry points into the network or to be used to pivot and extend the magnitude of the attack.
- Physical security: Unlike the traditional power system, smart grid network includes many components and most of them are out of the utility's premises.
- The lifetime of power systems. This equipment might act as weak security points and might very well be incompatible with the current power system devices.
- Implicit trust between traditional power devices: Device-to-device communication in control systems is vulnerable to data spoofing where the state of one device affects the actions of another.
- Different Team's backgrounds: Inefficient and unorganized communication between teams might cause many bad decisions, leading to serious vulnerabilities.
- Using Internet Protocol (IP) and commercial off-the-shelf hardware and software vulnerable to many IP-based network attacks such as IP spoofing, Tear Drop, Denial of Service, and others.
- More stakeholders: Having many stakeholders might give raise to a very dangerous kind of attack: insider attacks.

The reference document [22] analyses the smart grid scenario, its potential and the dangers it entails. The report includes 10 security recommendations aimed at both the public and private sectors, which are responsible for defining and implementing the smart grid. To this end, research and expert interviews were conducted (50 of 304 experts contacted participated in the study, and 23 personal interviews were conducted), resulting in a series of key findings, from which the recommendations were extracted. In line with the above, reference [23] summarises the cybersecurity requirements for the smart grid including

attack detection and resilience operations, identification, authentication and access control and secure and efficient communication protocols. On the other hand, in the reference article [24] an application of the "defence in Depth" security design principle is made, including a table in which the security protocols to be included for each layer of the OSI protocol are specified:

In the report "Smart Grid Set of Standards" [25], a map of standards and norms is represented, selecting standards such as IEEE 1686, ISO 27, 019, or IEC 62,443 to define what to do, and standards such as IEC 62, 351 to define how to do it.

Fig. 3. represents very well the standards to be considered, taking into account the main actors, which are the manufacturer of the equipment to be integrated into the infrastructure (vendor), the integrator who selects this equipment, acquires it, configures it and finally installs it and the operator, who uses and maintains it and is ultimately responsible for it (operator). This graph shows the importance that the European working group gives to the central standards of this paper, IEEE 1686 [26] and the different parts of IEC 62,351 [26]. Also, of utmost importance for completing the measures at organizational and procedural level are the IEC 62,443 standard for establishing and operating a security program in industrial environments, ISO/IEC TR 27, 019, for completing the controls established in a framework according to ISO 27,000, and ISO/IEC 15,408 (Common Criteria), for evaluation and certification of compliance.

As has already been shown in previous paragraphs when explaining the evolution of the electricity grid towards the smart grid, the basis of this evolution is to bring "intelligence" to all levels of the substation, in the so-called intelligent electronic devices (hereinafter IEDs). Without prejudice to the other security measures that must be taken in an infrastructure at all IT and OT levels, the IEEE Std 1686TM-2013, IEEE Standard for Intelligent Electronic Devices Cyber Security Capabilities [26], hereinafter IEEE 1686, focuses exclusively on security measures that apply to IEDs for the electricity sector, their configurations (including configuration management software), access control, both local and remote, the management of their firmware and the cryptographic features that must be included. Although this standard was designed taking into account measures defined in the US by organizations such as North American Electric Reliability Corporation (NERC) in the Critical Infrastructure Protection (CIP) program and NIST, the measures it contains can easily be adapted to any other regulation or security plan, making the standard valid for any IED.

A very important detail to bear in mind, and which is adequately highlighted in [26], is that full compliance with this standard does not ensure an adequate level of security across the board. It is only one part, which must be complemented by other measures, which are listed in:

- Physical security: access control and monitoring of the perimeter where the IED is located.
- Secure management of IED passwords.
- Control of documents with sensitive information about the IED (technical manuals, diagrams, etc.).
- Real-time monitoring of IED status and alarms.
- Security training and awareness for company personnel.
- Security plans and procedures for personnel outside the company (integrators, rack suppliers, maintenance contractors, etc.).
- Control of plans and files containing sensitive information.

Chapter 5 of the standard specifies seven areas of security, which are summarized below (see Fig. 4.).

On the other hand, the main objective of IEC 62,351, Power systems management and associated information exchange -Data and communications security [27] is to "Undertake the development of standards for the security of the communication protocols defined by IEC TC 57, specifically the IEC 60,870-5, IEC 60,870-6, IEC 61,850, IEC 61,970 and IEC 61,968 series. Basically, the standard focuses on defining a set of measures for the most widely used communication protocols. Currently,

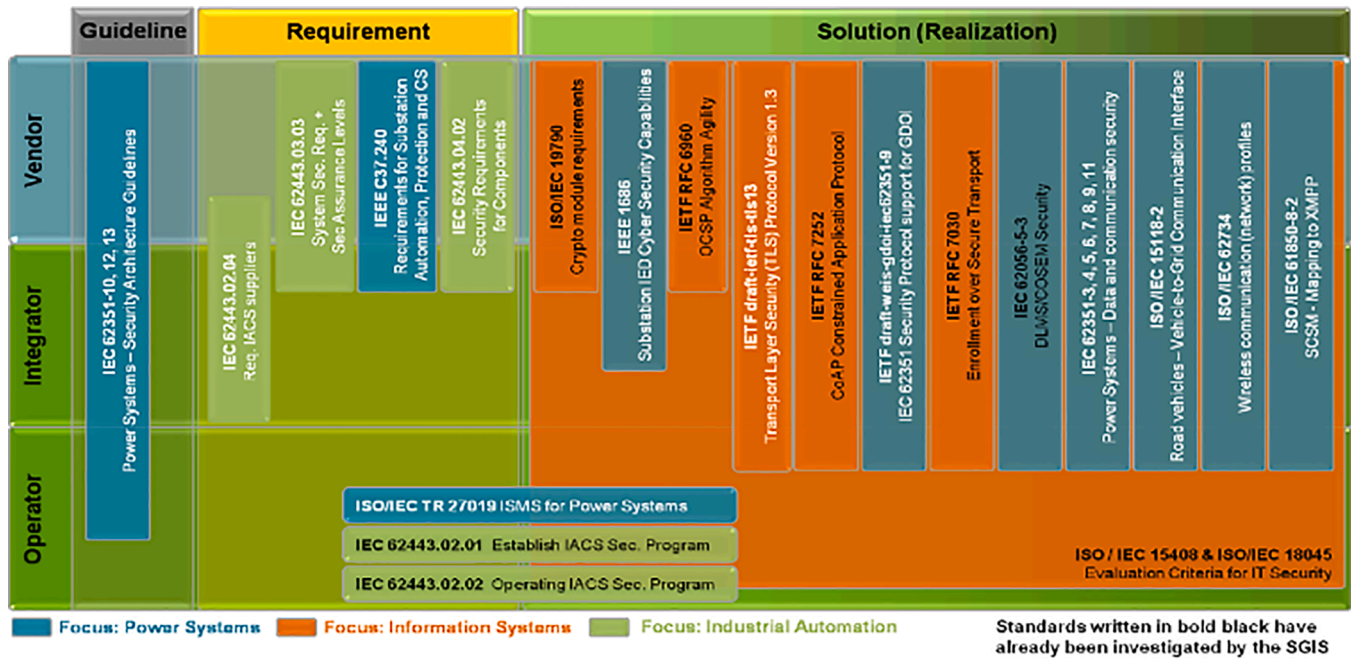


Fig. 3. Standards applicability map [25].

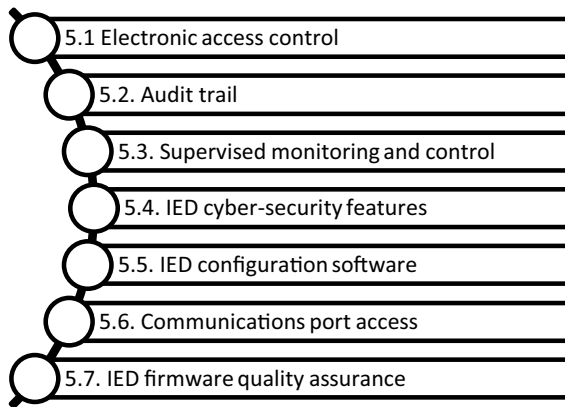


Fig. 4. Security areas covered in IEEE Std 1686.

IEC 60,870–5-x is mostly used in Europe in its different variants, 101 (serial) and 104 (TCP) for telecontrol, 103 (serial) for protection and 102 (serial) for energy meters, which have gradually displaced other protocols such as SAP20 and MODBUS. Schlegel et al. in [28] conclude that the standard can significantly improve security in energy systems if it is applied comprehensively. They also point out that the need to preserve (partial) backwards compatibility has resulted in systems that provide less safety than could have been achieved with a more ambitious approach.

In the Americas, DNP3 developed in IEEE Std 1815 [29], a protocol that is based on IEC 60,870–5, is mostly used, although it has been developed independently and is not backwards compatible. As stated in the reference article [30], this protocol has vulnerabilities in the validation of inputs that are not a flaw in its specifications, but in its implementation.

In the process of digitalization and evolution of the electricity sector, there is little discussion that the way forward is to make a transition to the IEC 61,850 standard [31], which is the evolution that aims to solve the problems posed by the current solution based on the aforementioned standards, and to be the basis on which the smart grid is built.

3. Method proposal

After studying the state of the art in relation to smart grid security, it can be deduced that, in a sector in which OT cybersecurity has not been a concern until recently (except at the perimeter), the path to follow does not seem clear, which is a major barrier in addition to the barriers inherent in a change of philosophy (costs, specification, temporary solutions for the installed base, etc.).

Therefore, this paper proposes a methodology to analyze the security level of CPS installed in smart grids based on the establishment of specific requirements and specific compliance tests. This methodology would be applied:

- When adding new equipment to the installation
- When modifying an existing equipment (upgrade, change of configuration, etc.)
- To assess an existing installation and reveal its weaknesses.

It takes into account an important detail, which is that in order to maintain an adequate level of security, it is necessary to take into account organizational aspects, such as policies and procedures, not only of the company responsible for the critical infrastructure, but also of the manufacturers, suppliers, integrators, etc., that is, of the supply chain that supports the operation, maintenance and expansion of the critical system.

Another aspect to be taken into account, so that this methodology can be put into practice, is interoperability. It is of little use for a piece of equipment to have all the security measures and guarantees if it is going to be integrated with equipment that does not support these measures, and it is therefore necessary to deactivate them so that they can communicate with each other.

The general stages of the methodology are presented in Fig. 5. The following sections develop these stages in detail.

3.1. Identification of requirements

For the identification of the requirements included as a representative example, ENSI level D requirements, IEEE 1686 and IEC 62,351 were consulted. This set of requirements is adapted to the scope of this

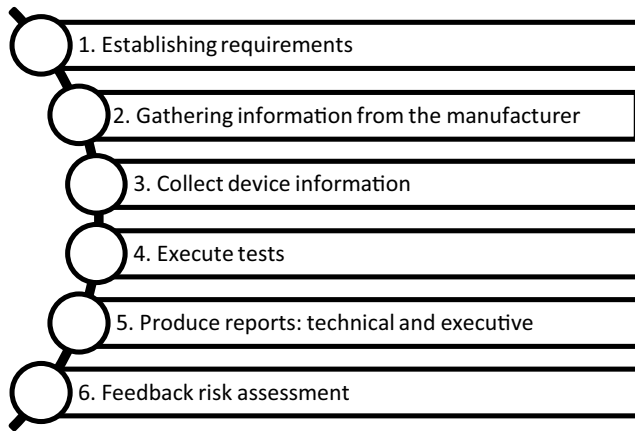


Fig. 5. Device evaluation methodology.

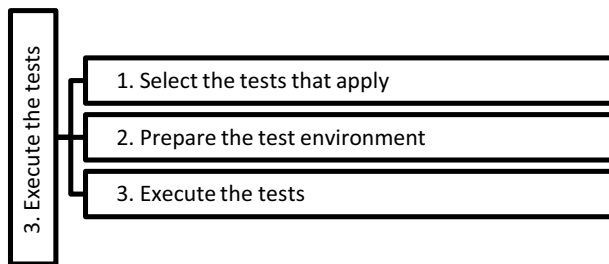


Fig. 6. Detail of Step 3 of the methodology: execute tests.

article, although in practice it will have to be extended and adapted according to needs. As much uniformity as possible should be retained when comparing results between devices or between configuration changes.

The requirements and controls to be evaluated shall be those shown in Table 2:

3.2. Gather information from the manufacturer

In this step, information about the manufacturer that may be relevant to security shall be collected. Any necessary certificates or evidence shall be requested and added as an annex to the executive report. This information will also be useful for tracking the evolution of a manufacturer.

3.3. Gather device information

In this step, both device identification and configuration information, as well as information on device security aspects, shall be collected. Device manuals, available certificates and collected evidence shall be added as an annex to the technical report.

Table 1
Layered security protocols [24].

Layer	Security protocol	Application
Application	WS-Security	Document
	PGP/GnuPG	Email
	S/MIME	
Transport	HTTP Digest Authentication	Client-to-Server
	SSH	
Network Link	SSL/TLS	Host-to-Host Point-to-Point Wireless Access
	IPSec	
	CHAP/PAP	
	WEP/WAP/802.1X	

Table 2
Requirements and controls to audit.

Control	Identifier	Requirement
Access control	ACCCON.1.	The device shall allow to manage at least 10 different users, defined by an identifier and its corresponding password.
	ACCCON.2.	The device shall be capable to manage following roles: Operator_OnlyView: Can see the operator windows but cannot issue commands. Operator: Can view operating screens and operate, issue commands, and acknowledge alarms. Simulate Values: Can simulate values and states (acquisition, measurement, and PLC). Configurator_OnlyView: Can see the configuration parameters. Configurator_ChangeConfig: Can view and modify the configuration parameters. Configurator_ChangeFirmware: Can update the firmware of the equipment. Configurator_ManageUsers: Can manage users and roles. Auditor_OnlyView: Can view the security log. Auditor: Can view and download the security log. Admin: Will have all rights. These roles can be assigned to different users, thus enabling them to perform the tasks defined for these roles, considering that they can only perform the tasks defined by the roles assigned to them.
	ACCCON.3.	The equipment shall have access control for each interface, either local or remote. If any interface, such as the local display, is to be active and unprotected, it shall be properly reported and an assessment shall be made as to whether compensatory security measures, e.g. physical measures, are necessary.
	ACCCON.4.	The system cannot be accessed with credentials other than those configured in Req.1. Password evasion mechanisms, such as push buttons or jumpers, are not allowed.
	ACCCON.5.	Passwords will not be displayed in clear text by any means and must be encrypted when stored or transmitted.
	ACCCON.6.	There will be no default or hidden users. If they exist in an initial or factory configuration, they will be able to be deleted or deactivated.
	Audit Trail	
	AUDREG.1.	The security log will have a capacity of 2048 security specific events. When filled, the oldest event will be overwritten, in a circular way.
	AUDREG.2.	The storage medium on which the security log resides shall be protected in such a way that it is impossible to remove it without causing irreparable damage on site.
	AUDREG.3.	The events to be sent to the log will be those significant to security, which at a minimum will include login and logout of each user, configuration change, date/time changes, firmware change, user/role management changes, and audit log download.
Communication protocols	COMPRO.1.	IEC 60,870-5-101 and IEC 60,870-5-104 shall implement the safety mechanisms specified in IEC 60,870-5-7.
	COMPRO.2.	DNP3 shall implement the security mechanisms specified in the IEEE 1815-2012 standard.
	COMPRO.3.	MMS, GOOSE and Sampled Values communications shall implement the safety mechanisms specified in the IEC 61,850 standard, in compliance with IEC 62,351-4 and IEC 62,351-6.

Table. 3

Capture of manufacturer's information.

Manufacturer's information	
Information security management system	ISO/IEC 27,001 NIST Cybersecurity Framework Other: _____ None
Risk Management	ISO/IEC 27,005 ISO 31,000 Other: _____ None
Has a secure Product Development Cycle implemented	Yes: _____ No
Customer service team available for 24/7 incident support	Yes: _____ Contact: _____ No
Vulnerability Management (Catalog, Detection, Correction, Publication)	Hardware Software No

Table. 4

Capture of general device information.

Device identification
Brand / Manufacturer
Model
Serial Number
Hardware Version
Firmware/software Version
Configuration Version
End-of-life date
Comments

Note: As stated in IEEE 1686, IEEE C37.231 may be consulted for additional details on the documentation of a particular release.

Table. 5

Capture of device security information.

Security information	
Standard components versions	Operating System: _____ Other components: _____
Development security tests	Static code analysis Dynamic analysis Penetration testing: Vulnerability scan Fuzzing testing Dictionary Attack Others: _____
Security principles	Defense in depth Security by default Least privilege Security events logging Avoid security by obscurity Identify third party dependencies Others: _____
Local Interfaces – Physical Ports USB, Ethernet, serial ports, local display, others	All ports shall be documented, as well as whether they have any mechanism to be deactivated.
Remote Interfaces – Services SSH, Telnet, FTP, HTTP, IEC 60,870–5–101, IEC 60,870–5–104, others	For services, specify their version. For communications protocols, attach interoperability profile to the documentation.
Security log recovery methods	SFTP WEB Other: _____ It has not security log
Password bypass/reset mechanism	Yes. Indicate which one, and services affected No

Table. 6

Test applicability.

Requirement	Test	Not Apply	Justification of non-applicability
ACCCON.1: At least 10 users, with user ID and password	1	☐	
ACCCON.2: Roles	1	☐	
ACCCON.3: Access Control in all interfaces	1	☐	
ACCCON.4: Password bypass	1	☐	
ACCCON.5: Password display in clear text	1 2 3	☐ ☐ ☐	
ACCCON.6: Default or hidden users / passwords	1 2 3	☐ ☐ ☐	
AUDREG.1: Security log size	1	☐	
AUDREG.2: Non-removable security log	1	☐	
AUDREG.3: Events in the security log	1	☐	
COMPRO.1: IEC 60,870-5-101 and IEC 60,870–5–104	1	☐	
COMPRO.2: DNP3	1	☐	
COMPRO.3: IEC 61,850	1	☐	

Table. 7

Test template.

Requirement/s	The requirement from which the test is derived shall be indicated.
Test number	Test number within the requirement.
Impact	Low, Medium, High.
Description	Test description.
Test preparation	Previous steps required to perform the test.
Test execution	Steps to execute the test.
Expected results or behavior	Events, behaviors, etc. to be verified in order to consider whether the test has been passed or failed. Evidences shall be captured an attached to the report.
Tester comments	Any additional helpful information.
Assessment	☐ Pass Test results and evidences. They can be included here, or a reference to external files can be added. ☐ Not pass ☐ Not apply

Table. 8

Gather manufacturer's information.

Manufacturer's information	
Information security management system	ISO/IEC 27,001 NIST Cybersecurity Framework Other: _____ None
Risk Management	ISO/IEC 27,005 ISO 31,000 Other: _____ None
Has a secure Product Development Cycle implemented	Yes: _IEC62443–4–1_ _____ No
Customer service team available for 24/7 incident support	Yes. Contact: _____ No
Vulnerability Management (Catalog, Detection, Correction, Publication)	Hardware Software No

Table. 9
Gather device information.

Device identification	
Brand / Manufacturer	Arteche
Model	saTECH BCU 142-55FMB2C4C4XXX-LT
Serial Number	170,000,000,001
Hardware Version	1.0
Firmware/software Version	1.0.0
Configuration Version	21.03
End-of-life date	Not specified
Comments	Ethernet port is optical fiber.
Security information	
Standard components versions	Operating System: Linux 4.9-BCU-XAL Others: -XOrg 8 -SSH 7.3
Development security tests	☒ Static code analysis ☐ Dynamic analysis ☒ Penetration testing: ☒ Vulnerability scan (Tenable Nessus) ☒ Fuzzing testing ☒ Dictionary Attack ☒ Defense in depth ☐ Security by default ☐ Least privilege ☒ Security events logging ☒ Avoid security by obscurity ☒ Identify third party dependencies ☒ Others: Attack surface reduction, CIS hardening
Local Interfaces – Physical Ports	Front: Color display to view and operate substation Text display to view and modify device settings microUSB to access to diagnostic port 2x general purpose USB ports (keyboard, mouse) 1x Ethernet port Back: 2x Optical Fiber Ethernet 4x RS232/485 serial port IRIG-B time synchronization (IN/OUT)
Remote Interfaces – Services	SSH, port 22 Maintenance Web, port 88 IEC 61,850 (MMS), port 102 VNC, port 5900, can be disabled NTP, port 123
Security log recovery methods	☒ SFTP Note: <i>Only some operating system events.</i> ☐ WEB ☐ Other: _____ ☐ It has not security log
Password bypass/reset mechanism	☐ Yes. Indicate which one, and services affected ☒ No

3.4. Execute the tests

In order to execute the tests, it is recommended to have a previous meeting with the manufacturer, in order to share the tests. It is important to understand the tests unambiguously and to clear any doubts before starting. The test execution process will be divided into the following steps:

- 1 *Select the tests that apply*: The tests shall be reviewed with the information gathered in Steps 1 and 2, and with support from the manufacturer if necessary. Tests that apply shall be ticked, and tests that do not apply shall be justified. The particular circumstances of the critical infrastructure owner or facility configuration shall always

Table. 10
Select the tests that apply.

Requirement	Test	Not Apply	Justification of non-applicability
ACCCON.1: At least 10 users, with user ID and password	1	☐	
ACCCON.2: Roles	1	☐	
ACCCON.3: Access Control in all interfaces	1	☐	
ACCCON.4: Password bypass	1	☐	
ACCCON.5: Password display in clear text	1 2 3	☐ ☐ ☐	
ACCCON.6: Default or hidden users / passwords	1 2 3	☐ ☐ ☐	
AUDREG.1: Security log size	1	☐	
AUDREG.2: Non-removable security log	1	☐	
AUDREG.3: Events in the security log	1	☐	
COMPRO.1: IEC 60,870-5-101 and IEC 60,870-5-104	1	☒	The test set has not 101 neither 104
COMPRO.2: DNP3	1	☒	The test set has not DNP3
COMPRO.3: IEC 61,850	1	☐	

Table. 11
Requirement ACCCON1 tests.

Requirement/s	ACCCON.1: Minimum of 10 users, with ID and password
Test number	1
Impact	High
Description	As many users as necessary will be created to reach a total of 10, taking into account the existing users.
Test preparation	Check user creation procedure in the device manual. Check number of users already existing on the device. Log in as a user with permissions to manage users (Configurator_Manage Users or Admin desirable). Initially there are 3 users.
Test execution	Create user User<n>, with password PassWord<n>, where (n) is the number of existing users plus 1. Have been reached 10 users? Yes, go to Step 3 No, repeat from Step 1, increasing (n) by 1 Write down the names of the users created
Expected results or behavior	The user is created correctly, being indicated by the interface used. The list of at least 10 users is completed.
Tester comments	Initially, user's admin, operator and config already exist. Users user1, user2, ... until user7 have been created.
Assessment	☒ Pass The system allows to create more than 100 users ☐ Not pass ☐ Not apply

be taken into account. A test should never be marked as not applicable by justifying that the equipment does not incorporate the feature. In that case, they do apply, but the corresponding tests will be marked as Not Passed. The idea of this table is that the same table can be used for any manufacturer, and it will be one of the bases for comparing different devices under the same conditions.

- 2 *Prepare the test environment*: The test environment will be documented, specifying the equipment to be used, how they are interconnected, configurations, tools, versions, and any information that allows to reproduce the test environment. The required test environment and tools shall be set up according to the above document and taking into account the tests to be performed. If any programs or tasks are run on the device under test to capture information or measure results, their impact on the tests shall be evaluated.

Table. 12
Requirement ACCCON2 tests.

Requirement/s	ACCCON.2: Roles
Test number	1
Impact	High
Description	It will be possible to create the following roles: • Operator_OnlyView • Operator • Simulate_Values • Configurator_OnlyView • Configurator_ChangeConfig • Configurator_ChangeFirmware • Configurator_ManageUsers • Auditor_OnlyView • Auditor • Admin
Test preparation	Review role creation procedure in the device manual. Review number of roles already existing on the device. Log in as a user with permissions to manage roles (Configurator_ManageUsers or Admin is desired).
Test execution	If roles already exist in the system, check that they belong to the above list. Create the missing roles until all the roles in the list in the description are registered.
Expected results or behavior	Roles are created correctly, being indicated by the user interface. The list of indicated roles is completed.
Tester comments	The system does not allow role management on all interfaces. Each user has fixed privileges defined, and they are segregated by service, so that the WEB interface users are independent from SSH users, for example.
Assessment	☐ Pass Role management is not yet ☒ Not pass ☐ Not implemented apply

Table. 13
Requirement ACCCON3 tests.

Requirement/s	ACCCON.3: Access control on all interfaces
Test number	1
Impact	High
Description	Verify that all interfaces identified in the equipment information require a username and password for access.
Test preparation	Device in the test environment, with interfaces accessible by type (serial, Ethernet, USB, etc.)
Test execution	For each identified interface: Access the service Enter incorrect username Enter correct username and incorrect password Enter correct username and password
Expected results or behavior	The service prompts for identification An error is obtained. It shall not indicate that the username is incorrect, it shall be a generic error. The event is recorded in the audit log. An error is obtained. It must not indicate that the password is incorrect, it must be a generic error. The event is recorded in the audit log. Access to the service is granted. The event is recorded in the audit log.
Tester comments	Display Operation: It prompts for credentials when issue commands. Display Configurariion: It prompts for credentials when changing some parameter. microUSB: OK SSH: OK Web: OK Telnet: OK VNC: OK
Assessment	☐ Pass Due to operation requirements, local displays ☒ Not pass cannot prompt for password. Additional controls ☐ Not should be needed to achieve required security apply level.

Table. 14
Requirement ACCCON4 tests.

Requirement/s	ACCCON.4: Password bypassing
Test number	1
Impact	High
Description	It shall be verified that the device does not have any mechanism to prevent access with username and password. If it does and it cannot be deactivated, it shall be proved that it only affects the services declared in the user's manual and/or in the equipment information.
Test preparation	Review the user's manual. Review the information collected about the equipment. Device in the test environment, with the interfaces accessible according to their type (serial, Ethernet, USB, etc.).
Test execution	If the device has no password bypass mechanism, this test does not apply. Activate password bypass mechanism, and for each identified interface: Access without password according to device manual
Expected results or behavior	Only the services declared as affected by the bypass mechanism allow access to the following.
Tester comments	
Assessment	☒ Pass The device does not have mechanisms to ☐ Not bypass passwords. pass ☐ Not apply

Table. 15
Requirement ACCCON5 tests.

Requirement/s	ACCCON.5: Passwords are not shown
Test number	1
Impact	High
Description	It shall be verified that the password is not displayed in plain text in any graphical interface, whether local display, web interface or similar.
Test preparation	Equipment in the test environment, with accessible interfaces.
Test execution	Collect passwords for all existing users. For each identified interface: Access the service Access all interface screens, in particular the historic and security log screens as well as the configuration screens.
Expected results or behavior	Check that none of the existing user passwords appear in plain text.
Tester comments	The Administration screen in the WEB interface displays the user list, but it does not contain its passwords.
Assessment	☒ Pass Any clear text password was found. ☐ Not pass ☐ Not apply

3 *Execute the tests*: Execute the proposed testing protocol - Record every evidence, whether or not the test is passed. To elaborate the test protocol, it has been taken into account that each requirement can be checked with one or more tests. A template is provided to assist in the creation of additional tests.

Every test is specified in accordance with the following template:
Templates have been made to define and record the result of each particular test case, which will be shown in the case of study.

3.5. Prepare reports: technical and executive

After the above steps, we should use all the information obtained from the manufacturer, from the device, and the test results, to prepare the reports:

Table. 16
Requirement ACCCON5 tests.

Requirement/s	ACCCON.5: Passwords are not shown
Test number	2
Impact	High
Description	It will be checked that the password is not visible in plain text in the configuration tool.
Test preparation	Access the equipment configuration tool. Identify operating system, installation path and storage technology (database, disk files, configuration server, etc.). Collect passwords of all existing users. Tool (T1) to search for text in files. Tool (T2) to perform searches according to where the tool stores device configurations.
Test execution	Open the device configuration tool Access all the screens, especially the user and role configuration screens Search for the passwords of the existing users in the directory where the application is installed using T1 Search for the passwords of the existing users in the database where the configuration is stored using T2
Expected results or behavior	Check that none of the existing user passwords appear in plain text Any password is found Any password is found
Tester comments	The configuration tool is using a local MySQL database. It is a Java application, but it is mostly used in the Microsoft Windows operating system. As T1 are used a) the Sysinternals strings command, and b) the Strings tab of the Process Explorer application, to check both file image and memory image of the executable. MySQL Workbench is used as T2. A database search is performed. The configuration tool has no user or role management screen.
Assessment	☒ Pass No plaintext password was found. ☐ Not pass ☐ Not apply

- Technical report:
 - Content: Summary of the tests, with the result, evidence, and comments/justifications.
 - Audience: Intended for evaluation of technical implications and details on compliance/non-compliance/justification.
- Executive Report:
 - Content Contains the collection of manufacturer and device information, the motivation for testing (new equipment, change in existing equipment, initial evaluation), and the equipment status of Suitable/Not Suitable.
 - Audience: It is intended for high-level officers and will be the contractual document.

The reports will include the persons responsible for the tests, the companies to which they belong and the date on which they were carried out.

3.6. Feedback to risk assessment

With the results obtained, the risks involved in integrating the equipment into the infrastructure must be identified, and the risk assessment previously performed on the infrastructure must be updated. The following cases may occur:

- There will be existing risks that are eliminated (because the new device replaces a less secure device).
- There will be risks that change to unacceptable levels and therefore require additional controls or safeguards to reduce the risk level.
- New risks will emerge, and they will need to be analyzed, assessed and, if necessary, addressed.

Table. 17
Requirement ACCCON5 tests.

Requirement/s	ACCCON.5: Passwords are not shown
Test number	3
Impact	High
Description	It will be verified that the password is not visible in plain text in the device's operating system.
Test preparation	Identify the device's operating system Gather login credentials with sufficient privileges to access the entire file system and all memory Collect passwords of all existing users Tool (T1) for text search in file system Tool (T2) for text search in RAM memory
Test execution	Access the system as a privileged user Search for the passwords of the existing users in the entire file system using T1 Search for the passwords of existing users in the entire RAM using T2
Expected results or behavior	Any password is found Any password is found
Tester comments	Linux operating system was found. Log in as root user. The T1 tool used is fgrep. Although already available on the device, we use one of our own, to guarantee the results (the existing one on the device could be modified). As a T2 tool, a capture of the memory is downloaded through the network to the Test PC by loading the LiME module, and this image is analyzed with the strings command. Note: The procedure followed to acquire the memory image was as follows: # insmod lime-2.6-ppc.ko "path=tcp:16,365 format=lime timeout=0" In TestPC the following command is executed: # nc 192.168.10.2 16,365 > imagen_mem_bcu_20,190,115.raw
Assessment	☒ Pass No passwords found on disk neither in memory. ☐ Not pass ☐ Not apply

- The detail of this point will depend on the methodology adopted by the critical infrastructure operator, so this methodology only identifies the need, and it is necessary to define how the risks will be fed back when adopting this methodology.

4. Methodology evaluation

4.1. Introduction

For the evaluation of the methodology, a SCU (Substation Control Unit), installed on level 2 of the substation, and a BCU (Bay Control Unit), installed on level 1, have been used. Due to the extension of this article, only the tests of the BCU IED are included.

The tests carried out have brought to light some security issues, which have provided valuable information for the organization, since their results have been used to incorporate new security requirements to future versions of the products, demonstrating the effectiveness of the methodology in its initial version.

4.2. Results of Bay Control Unit tests

The methodology has been used to evaluate the BCU (Bay Control Unit) device installed on level 1 of the substation. A system diagram is shown in the documentation of the test environment.

Step 1: Gather manufacturer's information

Step 2: Gather device information.

Step 3 Execute the tests

Step 3.2. Prepare the test environment

A test environment with real configuration has been installed, integrating both IEC61850 and DNP3 IP communications. Kali Linux will be

Table. 18

Requirement ACCCON6 tests.

Requirement/s	ACCCON.6: Default or hidden users / passwords	
Test number	1	
Impact	High	
Description	Check that there are no default users, or that they can be deactivated.	
Test preparation	Review the list of services declared in the device information. Review user's manual, to obtain the list of users and their passwords. Collect passwords for all existing users. They must be different from the default users. With the information about the device services and their versions, look for default credentials (for example, if the PostgreSQL database management system is used, it has as default credentials user postgresql and password postgresql). The use of a tool for automatic access testing will be preferred.	
Test execution	For each identified service: Test access with list of users in the manual Test access with list of default credentials of the service <i>Note: If a tool is used, specify which one in remarks</i>	
Expected results or behavior	Access is denied Access is denied	
Tester comments	The services exposed by the device do not contain default passwords. By default, exist the users root (maximum privilege), bcu and satechcnf. They cannot be disabled, but their passwords can be modified.	
Assessment	☒ Pass There are default users that cannot be modified or deactivated, but every password can be changed. ☐ Not pass ☐ Not apply	

Table. 19

Requirement ACCCON6 tests.

Requirement/s	ACCCON.6: Default or hidden users / passwords	
Test number	2	
Impact	High	
Description	It will be verified that there are no hidden, undocumented users	
Test preparation	heck the device information for the operating system. Review the list of existing users	
Test execution	Get the list of users of the operating system (for example, with the commands 'cat /etc./passwd' in Linux, or 'net users' in Windows). Compare it with the list of existing users.	
Expected results or behavior	No hidden user/password was found	
Tester comments	Only documented users have been found: - root with admin privileges - bcu with operator privileges - satechcnf with configurator privileges	
Assessment	☒ Pass No hidden users found ☐ Not pass ☐ Not apply	

used for the intrusion and dictionary attack tests, indicating in each test the interface and tool to be used to perform the test.

The test environment set up is a representative part of a substation architecture, which is depicted in Fig. 7.

The Fig. 8. shows the communications architecture and details of the environment:

Step 3.3. Execute the tests

Step 4: Prepare Technical and Executive reports

Both technical and executive reports will be additional documents. Here we represent a brief overview about they should contain.

- Technical report
- Report date: 14/01/2019

Table. 20

Requirement ACCCON6 tests.

Requirement/s	ACCCON.6: Default or hidden users / passwords	
Test number	3	
Impact	High	
Description	It will be verified that there are no hidden, undocumented users.	
Test preparation	Review the list of services declared in the device information. Review the user's manual, to get the list of users and their passwords. With a word processing tool, generate a dictionary (DIC1) containing all the words from the manufacturer's manuals, their web page, passwords from other devices, and other sources of words considered of interest. Use a tool (T1) to perform a brute force attack against the list of services, trying the words contained in DIC1. Note in Comments the tool and parameters used (Hydra, wfuzz, etc.). If a service cannot be tested, note it in Comments.	
Test execution	For each identified service: Use the T1 tool to attempt to brute force access to the service using DIC1.	
Expected results or behavior	No hidden user/password was found	
Tester comments	The tool named patator, very similar to Hydra but more reliable, is used. A dictionary is made with the cewl tool and the manufacturer's website.	
Assessment	☒ Pass No hidden users were found ☐ Not pass ☐ Not apply	

Table. 21

Requirement AUDREG1 tests.

Requirement/s	AUDREG.1: Audit trail capacity	
Test number	1	
Impact	High	
Description	Verify that the log capacity is at least 2048 events.	
Test preparation	Review in the device characteristics for audit trail capability (write down it as NEVENTS).	
Test execution	Generate NEVENTS events to be displayed in the audit log Generate one more events	
Expected results or behavior	The first event in the log corresponds to the first event generated, and the last event in the log corresponds to the last event generated The new event has been added, and the first event generated in Step 1 (the oldest one) has been deleted.	
Tester comments		
Assessment	☐ Pass There is no specific security log. ☒ Not pass The historical log has a maximum capacity of 1400 events. ☐ Not apply	

- Evaluation conducted by: Name (Company)
- Revised by: Name (Company)
- The test selection table, environment documentation, test protocol and evidence will be included below.
- Executive Report
- Report date: 16/01/2019
- Evaluation conducted by: Name (Company)
- Revised by: Name (Company)

4.2.1. Summary of the evaluation and conclusions

The result of the evaluation of the device by the infrastructure manager was ADEQUATE. The following shortcomings should be taken into account:

- The infrastructure operator's security program will require in the short term the integration of users and roles in the device.

Table. 22

Requirement AUDREG2 tests.

Requirement/s	AUDREG.2: Non-removable security log	
Test number	1	
Impact	High	
Description	Verify that the storage medium containing the security log cannot be removed without damaging the device.	
Test preparation	Review technical information of the audit log storage media. Ask to manufacturer if necessary.	
Test execution	Indicate procedure for extracting the storage medium on which the security log resides	
Expected results or behavior	Verify that the procedure involves damage to the device, requiring it to be sent to the manufacturer for repair	
Tester comments		
Assessment	☒ Pass ☐ Not pass ☐ Not apply	There is no specific security log. The general log resides in NVRAM soldered on board.

Table. 23

Requirement AUDREG3 tests.

Requirement/s	AUDREG.3: Events in the security register	
Test number	1	
Impact	High	
Description	Verify that the following types of events are correctly recorded: Login and logout Change of configuration Change of users and roles Date/time change Firmware change Download security log	
Test preparation	For this purpose, a user (USER1) will be created with roles that allows to change configuration, user, roles and firmware, and another user (AUDIT1) with permissions to download the security log. Review in the user's manual the procedures to make the indicated changes.	
Test execution	Log in as USER1 Modify some configuration parameter (e.g., device IP address, idle time, etc.). Create a new user USER2 Assign user USER2 the Admin role. Delete user USER2 Set the time forward by 3 h Change the day to the next day Load a new firmware version Log out as USER1 Log in as AUDIT1 Download the security log Log out as AUDIT1	
Expected results or behavior	The following events appear in the security log: Successful login of USER1 Configuration change User created USER2 Role assignment Admin to USER2 User deleted USER2 Manual date/time adjust. Old date/time, new date/time. Manual date/time adjust. Old date/time, new date/time. Firmware update USER1 logout Successful login of AUDIT1 Security log has been downloaded AUDIT1 logout	
Tester comments	Only login and logout events were recorded.	
Assessment	☐ Pass ☒ Not pass ☐ Not apply	There is no specific security log. Only login and logout events were recorded.

Table. 24

Requirement COMPRO1 tests.

Requirement/s	COMPRO.1: IEC 60,870–5–101 and IEC 60,870–5–104	
Test number	1	
Impact	High	
Description	It will be verified that the system has implemented the mechanisms and protocol extensions specified in IEC 60,870–5–7.	
Test preparation	Review the interoperability profile of the communications protocols. Review the PICS (protocol implementation conformance statement) document. Review the IEC 62,351–100–1 compliance document, which contains the compliance tests.	
Test execution	Tests as specified in IEC 62,351–100–1	
Expected results or behavior	All tests are passed successfully.	
Tester comments		
Assessment	☐ Pass ☐ Not pass ☒ Not apply	

Note: Due to the extent of these tests, it is beyond the scope of this article. However, the need to identify a specific additional test suite is reflected here, which in this case IEC 62,351–100–1 is proposed, although it can be complemented by existing manufacturer's or operator's test protocols.

Table. 25

Requirement COMPRO2 tests.

Requirement/s	COMPRO.2: DNP3	
Test number	1	
Impact	High	
Description	It shall be verified that the system has implemented the mechanisms and protocol extensions specified in IEEE 1815.	
Test preparation	Review the dnp3 device profile. Review the IEC 62,351–100–1 compliance document, which contains compliance tests for protocols based on IEC 60,870–5.	
Test execution	Pass the tests indicated in IEC 62,351–100–1 adapted to DNP3.	
Expected results or behavior	All tests are passed successfully.	
Tester comments		
Assessment	☐ Pass ☐ Not pass ☒ Not apply	

Note: Due to the extent of these tests, it is beyond the scope of this article. However, the need to identify a specific additional test suite is reflected here, which in this case IEC 62,351–100–1 is proposed, although it can be complemented by existing manufacturer's or operator's test protocols.

- Additional controls will be necessary to facilitate traceability if security incidents occur.

Step 5: Feedback risk assessment

This step, considering the reports generated, will be performed by the company owning the infrastructure where the device will be installed.

It may be necessary to implement compensating controls due to device weaknesses in order to maintain an adequate security level in the infrastructure.

5. Conclusions and outlook

The study of incidents that have directly and indirectly affected the energy sector has exposed details about threats, such as pieces of malware or organized criminal groups, advanced persistent threats, etc., and researchers have found in the analyses carried out by the various antivirus companies and security solutions a fantastic source of detailed information from which much can be learned about these threats.

Table 26
Requirement COMPRO3 tests.

Requirement/s	COMPRO.3: IEC 61,850
Test number	1
Impact	High
Description	It shall be verified that the system has implemented the mechanisms and protocol extensions specified in IEC 62,351–4 and IEC 62,351–6.
Test preparation	Review the ICD and CID of the device, to analyze the capabilities of the device. Review the IEC 62,351–100–4 and IEC 62,351–100–6 compliance documents, which contain the compliance tests.
Test execution	Execute the tests indicated in IEC 62,351–100–4 and IEC 62,351–100–6.
Expected results or behavior	All tests are passed successfully.
Tester comments	
Assessment	☐ Pass ☒ Not pass ☐ Not apply The device does not yet incorporate any protocol security mechanism.

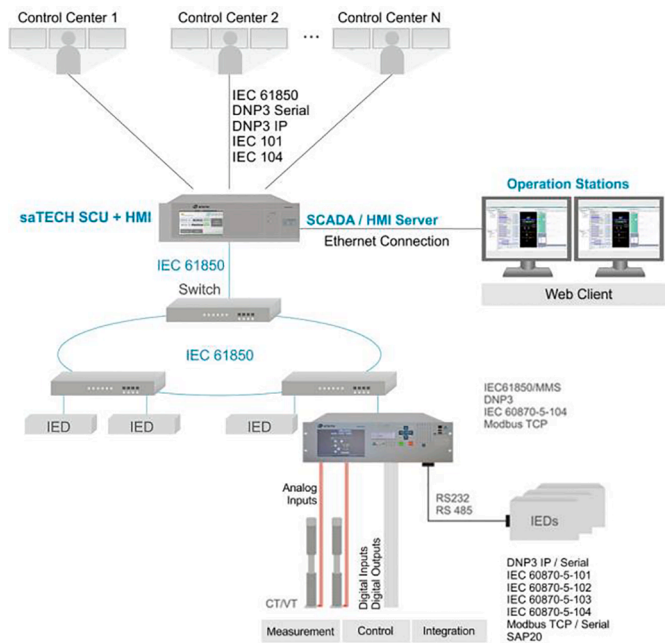


Fig. 7. General architecture of SATECH Substation Automation System.

The study of guides, standards and laws gives an insight into the fact that the problem of the lack of cybersecurity was detected a long time ago. A lot of work has been done on recommendations, guidelines, and standards, and it is taking a long time to translate all that work into practical measures that can be implemented in facilities.

Although it is true that measures are being taken, and the awareness of states, organizations and companies is increasing significantly, there is still a long way to go. For the development, integration, implementation, and maintenance of new technologies in the smart grid to be viable, and to achieve its objectives, cybersecurity aspects must be considered at all levels. And the issue that has been reflected in this article is that it is not yet clear how this will be done, as the laws are still at a very high level of specification.

The situation is even more complicated for technologies installed more than 15–20 years ago, which today are in production, obsolete and unsupported, which means great difficulties for infrastructure managers, who have to establish complex compensatory measures to reduce

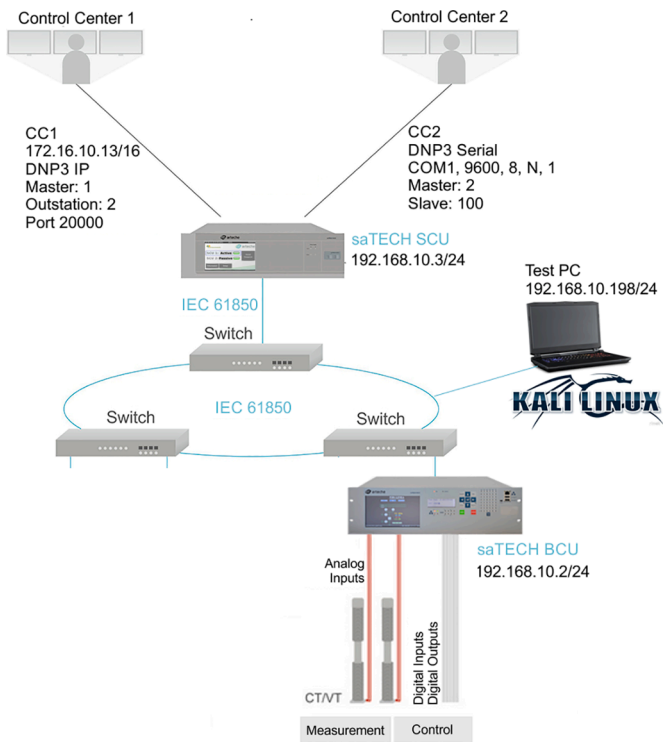


Fig. 8. Communications architecture and details of the environment.

the level of risk to acceptable levels, in a context in which incidents and attacks continue to increase and their complexity as well. Therefore, if no action is taken, it is only a matter of time before a serious incident occurs, a feeling that many electricity company managers have, as indicated in Section 2 above.

So, taking into account some of the shortcomings of cybersecurity in the electricity sector, a methodology has been proposed to establish a baseline on which to start improving the security of the devices that are installed or upgraded in substations (although it can be applied to any industrial control system). In its first version, the limitations of the methodology, which in turn are also its main lines of future work and improvement, are as follows:

- 1 Number of security requirements: the intention is to progressively add more security requirements and their associated compliance tests, this being one of the main lines of research and future work, which will make it possible to record the evolution of security.
- 2 Adding a test management tool: Within the testing culture, as the requirements grow, it will be necessary to use a test management tool, which facilitates the execution of tests, and allows the monitoring and planning of tests.
- 3 Automate test execution: Either in consensus with the manufacturers, who provide configurations adapted to the tests and facilitate them, or by adding test automation processes and tools, it is possible to reduce the time required in this initial version of the methodology.

The methodology opens the way for a large-scale work, which will allow us to provide security and resilience to a sector that, although it already has great importance for the development of society, this will be even greater in the coming years.

Declaration of Competing Interest

We wish to submit an original research article, entitled “A systematic approach to analysis for assessing the security level of cyber-physical systems in the electricity sector” for consideration by Microprocessors and

Microsystems journal. We confirm that this work is original and has not been published elsewhere, nor is it currently under consideration for publication elsewhere. We have no conflicts of interest to disclose. All authors have read the final manuscript, have approved the submission to the journal, and have accepted full responsibilities pertaining to the manuscript's delivery and contents.

References

- [1] V. Delgado-Gomes, et al., Smart grid security issues, in: Proceedings of the 9th International Conference on Compatibility and Power Electronics (CPE), IEEE, 2015, pp. 534–538, <https://doi.org/10.1109/CPE.2015.7231132>.
- [2] P. Bock, J.P. Huet, R. Françoise & R. Foley. Ukrainian power grids cyberattack. <https://www.isa.org/intech/20170406/>, 2017 (accessed 12 December 2020).
- [3] J. Edwards. DARPA mimics power grid cyber attack through 'Black Start' exercise. <https://www.executivegov.com/2018/11/darpa-mimics-power-grid-cyber-attack-through-black-start-exercise/>, 2018 (accessed 12 December 2020).
- [4] J. Marks. Pentagon researchers test 'Worst-Case Scenario' Attack on U.S. Power Grid. Nextgov. <https://www.nextgov.com/cybersecurity/2018/11/pentagon-researchers-test-worst-case-scenario-attack-us-power-grid/152803/>, 2018 (accessed 12 December 2020).
- [5] M.Á. Font, Pérdidas Millonarias en Menorca por los tres días sin Electricidad, El Mundo, 2018. <https://www.elmundo.es/baleares/2018/10/30/5bd7fd8aca4741bb618b45a2.html> (accessed 12 December 2020).
- [6] Red Eléctrica de España, La operación del sistema eléctrico para dummies. Centro Libros PAPF, S.L.U., Barcelona, 2013.
- [7] NIST, NIST Framework and Roadmap for Smart Grid Interoperability Standards, Institute of Standards and Technology, 2014. Tech. Rep. Release 3.0.
- [8] Novelec. Cómo funciona una Smart Grid? <https://blog.gruponovelec.com/electricidad/como-funciona-smart-grid/>, 2017, (accessed 12 December 2020).
- [9] J.P.A. Yaacoub, O. Salman, H.N. Noura, N. Kaaniche, A. Chehab, M. Malli, Cyber-physical systems security: limitations, issues and future trends, Microprocess. Microsyst. 77 (2020), 103201, <https://doi.org/10.1016/j.micpro.2020.103201>.
- [10] J. Hong, et al., Cyber-physical security testbed for substations in a power grid. Cyber Physical Systems Approach to Smart Electric Power Grid, Springer, Berlin, Heidelberg, 2015, pp. 261–301, https://doi.org/10.1007/978-3-662-45928-7_10.
- [11] M. Rossman, T. Ryan, M. Teichmann., Outsmarting grid security threats. Accenture Consulting. <https://www.cybersecitalia.it/wp-content/uploads/2018/01/Accenture-Outsmarting-Grid-Security-Threats-POV.pdf>, 2017 (accessed 12 December 2020).
- [12] P. Bock, J.P. Huet, R. Françoise, R. Foley. Ukrainian power grids cyberattack. <https://www.isa.org/intech/20170406/>, 2017 (accessed 12 December 2020).
- [13] J.F. Bolívar. Infraestructuras críticas y sistemas industriales: OxWORD computing. Madrid, 2016.
- [14] A. Cherepanov. Win32/Industroyer: a new threat for industrial control systems. <https://www.welivesecurity.com/wp-content/uploads/2017/06/Win32-Industroyer.pdf>, 2017 (accessed 12 December 2020).
- [15] Dragos, Inc. Team. TRISIS Malware. Analyzing safety system targeted malware. <https://dragos.com/blog/trisis/TRISIS-01.pdf>, 2017 (accessed 12 December 2020).
- [16] Santamarta, R. Go nuclear: breaking radiation monitoring devices (White Paper). <https://ioactive.com/wp-content/uploads/2018/05/Go-Nuclear-Breaking-Radit on-Monitoring-Devices-Final-1.pdf>, 2017 (accessed 12 December 2020).
- [17] M. Molist, Un 'Hacker' Español Descubre un grave Fallo de Seguridad en Centrales Nucleares, El Confidencial, 2017. https://www.elconfidencial.com/tecnologia/2017-07-07/ruben-santamarta-ciberseguridad-nucleares-ciberataque-blackhat_1410510/ (accessed 12 December 2020).
- [18] R. Sherstobitoff, A. Malhotra. Operations sharpshooter. <https://www.mcafee.com/enterprise/en-us/assets/reports/rp-operation-sharpshooter.pdf>, 2018, (accessed 12 December 2020).
- [19] J. Landry, U. Shamir, Malware Discovered-SFG: furtim Malware Analysis, SentinelOne, 2016. <https://www.sentinelone.com/blog/sfg-furtim-parent/> (accessed 12 December 2020).
- [20] C. Osborne. Irongate malware targets industrial systems, avoids detection. <https://www.zdnet.com/article/irongate-malware-targets-industrial-systems-avoids-detection/>, 2016 (accessed 12 December 2020).
- [21] F. Loula, A.R. Al-Alia, R. Al-Dalkya, M. Al-Mardinia, W. El-Hajj, Smart grid security: threats vulnerabilities and solution, Int. J. Smart Grid Clean Energy 1.1 (2012) 1–6.
- [22] E. Egozcue, et al., Smart Grid Security: Recommendations for Europe and Member States, ENISA, Heraklion, Greece, 2012.
- [23] W. Wang, L.U. Zhuo, Cyber security in the smart grid: survey and challenges, Comput. Netw. 57 (5) (2013) 1344–1371, <https://doi.org/10.1016/j.comnet.2012.12.017>.
- [24] Y. Yan, Y. Qian, H. Sharif, D. Tipper, A survey on cyber security for smart grid communications, IEEE Commun. Surv. Tutor. 14 (4) (2012) 998–1010, <https://doi.org/10.1109/SURV.2012.010912.00035>.
- [25] CEN-CENELEC-ETSI Coordination Group on Smart Energy Grids (CG-SEG). SEGCG/M490/G Smart Grid Set of Standards Version 4. (2017).
- [26] IEEE Power and Energy Society, IEEE Std 1686™-2013: IEEE Standard for Intelligent Electronic Devices Cyber Security Capabilities, The Institute of Electrical and Electronics Engineers, Inc, New York, 2013.
- [27] International Electrotechnical Commission, IEC TS 62351-Part 1: Communication Network and System Security-Introduction to Security Issues (2007).
- [28] R. Schlegel, S. Obermeier, J. Schneider, Assessing the security of IEC 62351, in: Proceedings of the 3rd International Symposium for ICS & SCADA Cyber Security Research 3, 2015, pp. 11–19.
- [29] IEEE 1815-2012 IEEE standard for electric power systems communications-distributed network protocol (DNP3).
- [30] A. Siddavatam, F. Kazi, Security assessment framework for cyber physical systems: a case-study of DNP3 protocol, in: Proceedings of the IEEE Bombay Section Symposium (IBSS), Mumbai, 2015, pp. 1–6, <https://doi.org/10.1109/IBSS.2015.7456631>.
- [31] R.E. Mackiewicz, Overview of IEC 61850 and Benefits, in: Proceedings of the IEEE Power Engineering Society General Meeting, 2006, <https://doi.org/10.1109/PES.2006.1709546>, p. 8 pp. 1.



Miguel Angel Sanchez Rodriguez is Head of Cybersecurity in the R&D department at Artech. With more than 11 years of experience in the electrical sector, working in the whole development life cycle of control devices, he received his master's degree in Cybersecurity from Universidad Internacional de la Rioja (UNIR), is Incident Response Certified Professional by Securizame, and a cybersecurity enthusiast. He is responsible of Artech Cybersecurity Laboratory, collaborates with the maintenance of ISO27001, and is implementing and improving the S-SDLC based on IEC 62,443–4–1. He collaborates with international standardization working groups, such as IEC, IEEE and CIRE.



Javier Bermejo Higuera received the B.S. degree from Alcala University and his Ph.D. degree from Army Polytechnic School. Currently, he is Professor in the Escuela Superior de Ingeniería y Tecnología at Universidad Internacional de La Rioja (UNIR). He is an author of several publications. His research interests include the fields of software security, cybersecurity and malware analysis.



Juan Ramón Bermejo Higuera is currently chief of cybersecurity unit at National Institute of Aerospace techniques of Spain. He is a professor of applications security in the International University of La Rioja and he also is an associate professor of Cyberdefence Master Science degree in the Alcala de Henares University. He received the M.Sc in computer engineering degree from Distance Education National University of Spain in 1998 and the Ph.D degree from Distance Education National University at 2014. He is an author of several publications. His research interests include cybersecurity and cyber defense.



Juan Antonio Sicilia Montalvo received the B.S. degree and his Ph.D. degree from Universidad de Zaragoza. Currently, he is Professor in the Escuela Superior de Ingeniería y Tecnología at Universidad Internacional de La Rioja (UNIR). His research interests include combinatorial optimization, computer security, software development based on mathematical algorithms, numerical methods, and heuristic techniques for solving engineering problems.



Ruben Gonzalez has a Ph.D. in Computer Science Engineering. Currently he is Vice Chancellor for Academic Planning and Teaching Staff of the International University of La Rioja. He is also the Founder and Chief Editor of the International Journal of Interactive Multimedia and Artificial Intelligence and Associate Editor of indexed scientific journals. He is an advisor and collaborator of the Ministry of Education, both Spanish and Colombian, in the field of quality education, mainly university. Previously he was Director of the Higher School of Engineering and Technology (ESIT), Director of the UNIR-AENOR Chair and Postgraduate Director at the Pontifical University of Salamanca, as well as in charge of the Chair of Operating Systems at

the same university. He founded and directed the GISTI Research Group participating in several competitive research projects. He was a visiting professor for more than eight years at the University of Oviedo. He has published more than 180 articles in indexed journals and prestigious national and international conferences. He has given many seminars and conferences in Europe and Latin America on Project Management, Artificial Intelligence, Industry 4.0 and has received various awards related to his activity. His research focuses on Web Accessibility and Usability, Educational Technology as well as Soft Computing techniques in Artificial Intelligence. Within his Technology Transfer activities, he is an evaluator of international projects for the FECyT, SENACYT and COLCIENCIAS, among others, collaborates in different committees with AENOR, and participates as Principal Investigator in H2020 and national projects. Rubén is Senior Member of IEEE.